

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	<i>The data leak occurred because the manager failed to revoke access to the internal folder after the sales meeting, violating the principle of least privilege. The sales representative then accidentally shared a link to the entire restricted folder instead of only the approved promotional materials. There was no automated access control or oversight mechanism to prevent unauthorized sharing of sensitive documents.</i>
Review	<i>NIST SP 800-53: AC-6 addresses the principle of least privilege, which requires that users are only granted the minimum access necessary to perform their job functions. It emphasizes that processes, roles, and user accounts should be enforced to prevent anyone from operating at privilege levels beyond what their business objectives require. The control also includes enhancements such as restricting access by role, automatically</i>

	<i>revoking access after a set time, and regularly auditing user privileges.</i>
Recommendation(s)	1. Restrict access to sensitive resources based on user role (AC-6 Enhancement): Access to internal folders containing confidential business documents should be limited to employees whose roles require it, rather than being shared broadly during meetings. 2. Automatically revoke access to information after a period of time (AC-6 Enhancement): Temporary access granted for purposes such as a sales meeting should expire automatically, ensuring that employees and external parties do not retain access to sensitive folders beyond the intended timeframe.
Justification	<i>How might these improvements address the issues?</i> Restricting folder access by user role would have prevented the sales representative from ever having access to the confidential internal documents in the first place, making accidental sharing impossible. Implementing automatic access expiration would have acted as a safety net by ensuring the manager's oversight did not create a lasting vulnerability. Together, these enhancements reduce both human error and the window of opportunity for data leaks.

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.